IQRASEC ACADEMY

Content Discovery Report

WAPT Phase 1

Task 2 Reconnaissance and Enumeration

Prepared by

Kinza Noor

Report date

3 October 2026

Learning platform

TryHackMe

Description:

This report documents a workflow for mapping web resources and checking discovery results. It follows the Content Discovery room and includes practical instructions, observation fields and screenshot placeholders. Complete these fields with evidence from your own lab before submission.

Table of Contents

1 Objective 3
2 Concept and Understanding 3
2.1 Content Discovery Methods 3
2.2 Common Files and Metadata 3
2.3 Directories DNS and Virtual Hosts 3
2.4 Validation and False Positives 3
3 Practical Work 3
3.1 Lab Setup 3
3.2 Common File Inspection 3
3.3 Headers and Framework Inspection 3
3.4 OSINT Review 4
3.5 Directory Enumeration 4
3.6 DNS Enumeration 4
3.7 Virtual Host Enumeration 4
4 Tools Used 5
5 Evidence 5
7 Key Learnings 6
8 References 6

1 Objective

To identify unlinked web resources, interpret application metadata and compare manual investigation with automated enumeration. The practical goal is an evidence-backed inventory of URLs and hostnames that can support later web application testing.

2 Concept and Understanding

2.1 Content Discovery Methods

Manual discovery inspects a website and its responses. OSINT reviews information published through external services. Automated discovery tests candidate names from wordlists. Combining these methods improves coverage because any individual source can miss resources.

2.2 Common Files and Metadata

robots.txt supplies crawler instructions; it does not enforce authentication or prevent direct requests. A sitemap lists URLs for crawlers and can help map the application. Response headers and HTML comments may disclose technology clues. Treat a reported product or version as an observation requiring validation, rather than proof of a vulnerability.

2.3 Directories DNS and Virtual Hosts

Directory discovery varies the URL path. DNS enumeration tests candidate hostnames against a resolver. Virtual-host enumeration varies the HTTP Host header so that one server can select different applications. A hosts-file entry supports local name resolution; it does not create a DNS record.

2.4 Validation and False Positives

A 200 response means the request succeeded, but the body may be a generic error page. A 301 or 302 response indicates redirection; inspect its destination. A 403 response indicates refusal, not permission to access protected content. Compare candidate responses with a deliberately nonexistent path or hostname before treating them as findings.

3 Practical Work

3.1 Lab Setup

Start the room machine and use the AttackBox or a Kali system connected through the TryHackMe VPN. Replace MACHINE_IP in every command with the current target IP. Record tool versions and the wordlist paths actually available on your system.

3.2 Common File Inspection

http:// 192.168.23.12/robots.txt
http:// 192.168.23.12/sitemap.xml

Open both addresses in the lab browser. Record crawler exclusions and unusual sitemap entries, then request the relevant paths directly to check their responses. Capture each file with its address visible.

3.3 Headers and Framework Inspection

curl -v http:// 192.168.23.12

Inspect response headers, including the task's X-FLAG header. View the page source and follow its framework documentation link. Use the administration route and supplied lab credentials admin / admin for the assigned exercise. Record the route and outcome from your own session.

3.4 OSINT Review

Review the room's search-engine operators, technology identification, archives, repository history and cloud-storage naming concepts. If you perform additional research, record the public domain used and the specific source supporting each observation. Private .thm lab names generally do not have public search results.

site:PUBLIC_DOMAIN filetype:pdf
site:PUBLIC_DOMAIN inurl:login

Use an authorized public domain in place of PUBLIC_DOMAIN. Record any Wappalyzer technology identification, archived URL or relevant public repository separately from live lab findings. An archive can be outdated and technology detection can be incomplete. Do not label conceptual exercises as completed scans.

3.5 Directory Enumeration

```
gobuster dir -u http://MACHINE_IP \
  -w /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt \
  -o content-dir.txt
```

Use gobuster dir --help to check the installed options. Review the discovered paths, status codes, sizes and redirects. Open candidate resources in the browser to verify them. Save the output and identify the directory beginning with /mo and the log file requested by the exercise.

Directory requested by task: [Enter result]
Log file discovered: [Enter result]
Verified URL and response: [Enter details]
Evidence: Figure 6.

3.6 DNS Enumeration

The AttackBox instructions configure the lab DNS resolver through /etc/resolv-dnsmasq and restart dnsmasq. On Kali, an explicit resolver is often clearer. The command below uses the target as resolver. Set LAB_DOMAIN to the domain confirmed in your current task.

```
gobuster dns  -r 192.168.23.12 \
  -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt \
  -o content-dns.txt
```

The room examples use example.thm, while its final virtual-host question names acmeitsupport.thm. Confirm which domain your exercise uses before scanning. If wildcard DNS is detected, compare random names with candidate results. The --wildcard option forces continuation; it does not validate discovered names.

3.7 Virtual Host Enumeration

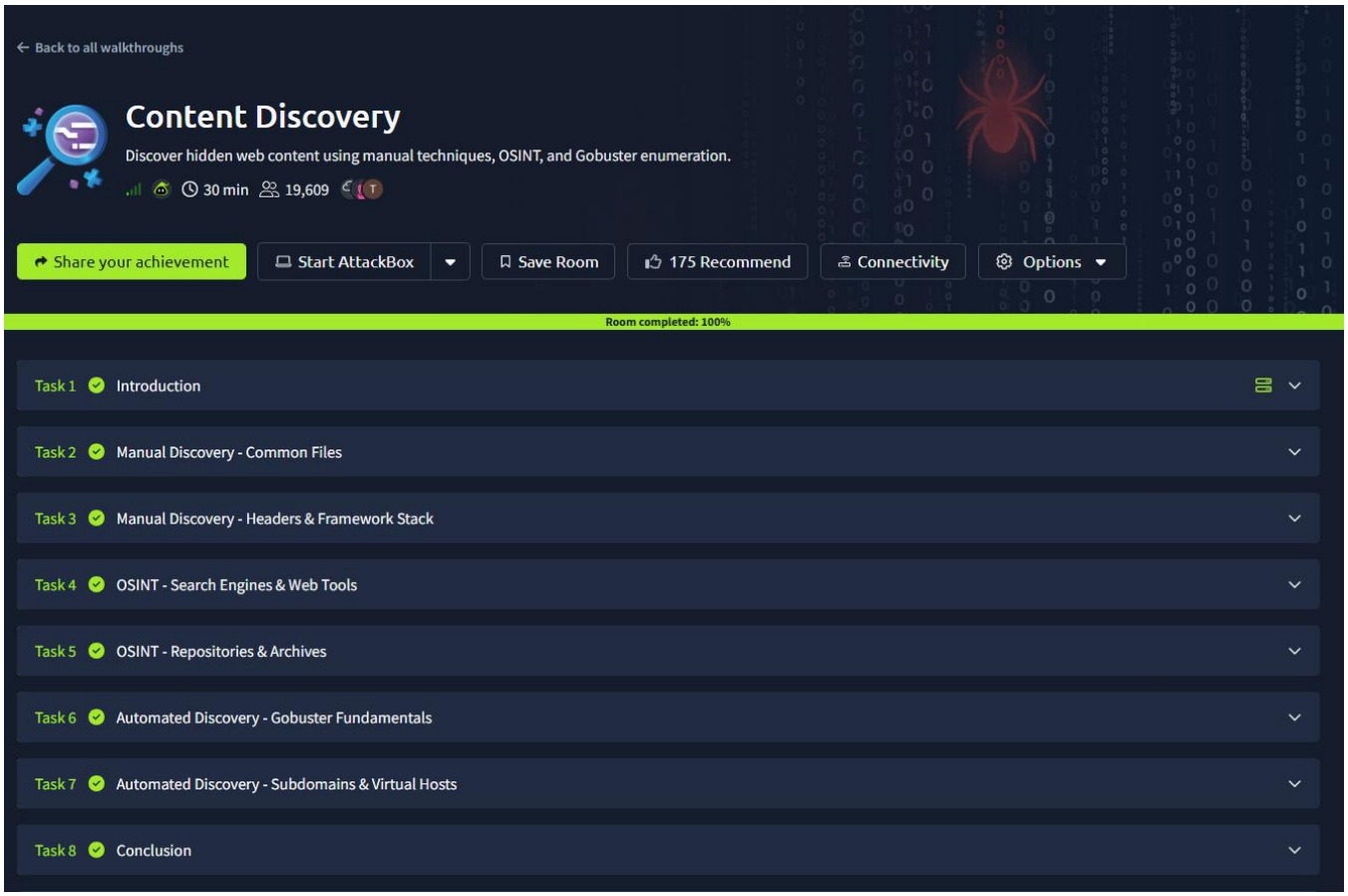
Check vhost --help for your version. Compare responses to an unknown Host value. Apply --exclude-length only after measuring a consistent irrelevant response size; an arbitrary range can hide valid results. Verify candidates using the Host header, then map confirmed names in /etc/hosts when needed for browser access.

curl -i -H "Host: FOUND_HOSTNAME" http://192.168.23.12/

4 Tools Used

Tool	Purpose
Browser and page source	Review content, links and source comments.
curl	Inspect headers and verify candidate HTTP responses.
Gobuster and SecLists	Enumerate paths, DNS names and virtual hosts.
Wappalyzer	Review reported web technologies when used.
Search engine and Wayback Machine	Review indexed or historical public content.
GitHub	Review relevant public source and commit history.

5 Evidence



7 Key Learnings

Unlinked resources can expand the application map, but discovery requires response verification. Crawler exclusions do not replace access controls. DNS names and HTTP virtual hosts use different mechanisms, so their results need separate interpretation. Wordlists, resolver settings and response filters determine what an automated scan can reveal.

For any confirmed exposure, explain what was actually accessible and why it matters. Appropriate improvements may include enforcing authorization, removing unnecessary public files and changing default credentials. Apply recommendations to demonstrated findings rather than assuming that every discovered URL is a vulnerability.

8 References

TryHackMe. Content Discovery. https://tryhackme.com/room/contentdiscoveryx

Gobuster official repository and usage. https://github.com/OJ/gobuster

Google Search Central. Introduction to robots.txt. https://developers.google.com/search/docs/crawling-indexing/robots/intro

MDN Web Docs. HTTP response status codes. https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Status